

Lezione 2 – Cyber-Physical Security

Terminologia di Sicurezza

Dario Stabili

Corso di Laurea Triennale in Ingegneria Informatica – Sede di Mantova
Dipartimento di Ingegneria “Enzo Ferrari” (DIEF)
Università degli Studi di Modena e Reggio Emilia
a.a. 2026–2027



UNIMORE
UNIVERSITÀ DEGLI STUDI DI
MODENA E REGGIO EMILIA

Crimini ad alta tecnologia in aumento

- High tech Crime
- Cybercrime
- Computer crime
- Crimine informatico
- Internet Crime
- Web crime
- Digital crime
- ...

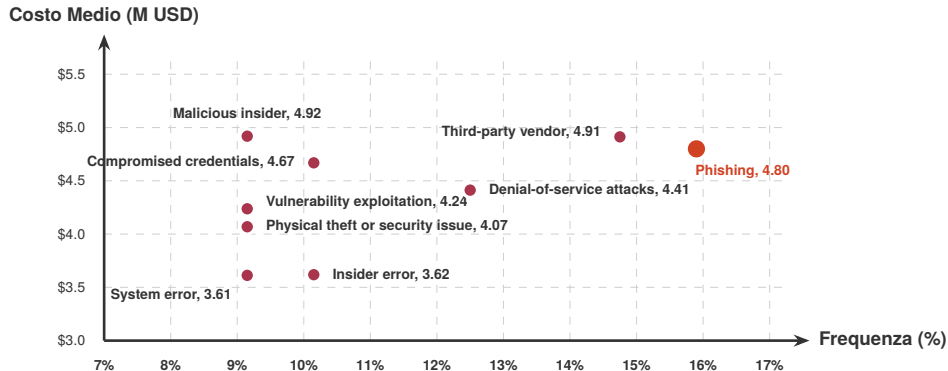
Tutte definizioni che rappresentano i crimini perpetrati mediante l'impiego di sistemi elettronici, che oggi utilizzano principalmente tecnologie digitali.

Altro esempio: Phishing

- Perché esiste ancora il phishing (come evoluzione dello *spam*)?
- Chi può credere e anticipare soldi per una mail che:
 - ti annuncia di aver vinto 100.000€ ad una lotteria a cui non hai mai partecipato?
 - ti “regala” il 10% di 10M di dollari per far transitare i soldi
 - del solito figlio perseguitato di qualche dittatore africano?
- Eppure “allo spammer basta che lo 0,0001% dei milioni dei destinatari delle loro e-mail risponda positivamente per arrivare a guadagnare dai 7.500 ai 12.500 dollari al giorno!”

Altro esempio: Phishing

Frequenza e Costo Medio dei Vettori Iniziali di Attacco



Crimini penali: Pedopornografia, furti di identità, ricatti, spionaggio industriale, ...

- “1 out of 5 children received a sexual solicitation or approach over the Internet in a one-year period of time”
- “California warns of massive ID theft: Personal data stolen from computers at University of California, Berkeley”
- Possono cercare di rubare i numeri delle carte di credito, del conto Paypal, di eBay, dei dati dell'online banking
- Ma anche i dati di accesso ai giochi online. Esempi (veri):
 - possono rubare le “spade magiche” e poi ricattare per restituirle
 - possono usare un'utenza di poker online per saccheggiare tutti i soldi di quel conto
- Numerosi casi eclatanti di aziende colpite a scopo di:
 - truffe, estorsione
 - furto di brevetti/idee
 - furto di informazioni commerciali rivendute a loro concorrenti

In sintesi

- Le tecnologie digitali possono essere **obiettivo** del crimine
- Le tecnologie digitali possono essere utilizzate come **strumento** del crimine
- Le tecnologie digitali possono essere utilizzate come **testimoni** del crimine

In sintesi

- Le tecnologie digitali possono essere **obiettivo** del crimine
- Le tecnologie digitali possono essere utilizzate come **strumento** del crimine
- Le tecnologie digitali possono essere utilizzate come **testimoni** del crimine
- **Le tre possibilità non sono mutuamente esclusive!**

Dove sono le colpe?

- Molti (impropriamente) accusano l'infrastruttura e le tecnologie che si utilizzano in Internet
- Ironicamente, **Internet è stata progettata per promuovere il massimo scambio (non ristretto) di informazioni accademiche e scientifiche**

Dove sono le colpe?

- L'errore non è nel progetto, ma nell'avere cambiato gli obiettivi e l'uso: Internet è diventata un sistema di interconnessione e di comunicazione globale dove vengono trasmessi anche dati sensibili e riservati
- Inoltre, le tecnologie Web hanno reso estremamente facile l'utilizzo dei servizi Internet a una platea (>2 miliardi) di non esperti

Rischio

- È la probabilità che una determinata **minaccia** ha di sfruttare la **vulnerabilità** di una **risorsa (asset)** e quindi di causare **impatti indesiderati**

Vulnerabilità tecnologiche

- **Evoluzione dei sistemi informatici**

- **Prima:**

- Sistemi informatici (CED) non collegati a reti esterne
- Mainframe centrale e terminali “stupidi” (solo video/tastiera)
- Connessioni dedicate, sempre wired, non condivise

- **Oggi:**

- Miliardi di sistemi collegati a Internet
- Data center con server distribuiti su reti LAN e WAN
- Terminali intelligenti (PC, smartphone, ecc)
- Reti non dedicate
- Trasmissioni digitali di voce e qualunque tipo di dati
- Reti wireless

Vulnerabilità tecnologiche

- **Evoluzione delle applicazioni e servizi informatici**

- **Prima:**

- Poche applicazioni informatiche indispensabili per il funzionamento complessivo dell'organ
- Poche informazioni digitalizzate e memorizzate in database
- Pochi dipendenti autorizzati ad accedere alle informazioni digitali
- Poche applicazioni (forse nessuna) con vincoli di interattività e di disponibilità determinanti per il successo dell'organizzazione

- **Oggi:**

- Applicazioni informatiche diffuse
- Tutte, ma proprio tutte, le informazioni (anche) in formato digitale
- Molteplici applicazioni devono essere sempre attive, almeno nelle ore di ufficio, e molte operazioni avvengono di notte non presidiate

Vulnerabilità tecnologiche

- **Sistemi informatici sempre più complessi, eterogenei ed integrati**
- Architetture multi-piattaforma
- Necessità di cooperazione: tra livelli e piattaforme, tra servizi e applicazioni: gestionali, servizi di rete, progettazione, produzione, \ ...
- Numero di utenti crescente e non necessariamente con competenze informatiche: dipendenti, clienti, fornitori, personale amministrativo, \ ...
- A causa dell'integrazione dei sistemi informatici, danni provocati da un utente potrebbero ripercuotersi su gran parte dell'organizzazione

Altra vulnerabilità: complessità

- **Evoluzione dei sistemi informatici sempre più complessi da proteggere in quanto coinvolgono competenze differenziate che non sono facilmente conciliabili**
- Discipline informatiche:
 - sistemi di autenticazione
 - sistemi di protezione logica
 - reti
 - protocolli di crittografia, \dots{}
- Discipline giuridiche:
 - normative sulla privacy
 - legislazione vigente in continua evoluzione, \dots{}
- Altre discipline:
 - psicologia
 - sicurezza fisica degli ambienti, Antincendio, videosorveglianza, \dots{}
- organizzazione aziendale

Ma anche vulnerabilità dovute a...

- **Sviluppatori Software**

- Il software contiene molti bug
- Non vi è educazione allo sviluppo di software sicuro

- **Sistemisti**

- I sistemi operativi ed applicazioni non vengono aggiornati né
- patchati con regolarità
- L'autenticazione della maggior parte dei servizi è debole

- **Management**

- Mancanza di sensibilità adeguata sui problemi relativi alla sicurezza
- Problemi di budget

- **Personale**

- Mancanza di cultura e sensibilità adeguata (post-it, scelta password,
- gestione attachment di email, \. . .) → rischi di social engineering

Vulnerabilità indotte dal Time-to-Market

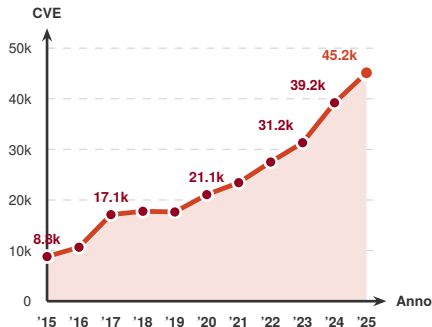
Evoluzione delle Segnalazioni CVE (2015 – 2025)

- **Bug del software e pressione di mercato**

I software presenti sul mercato, a causa della necessità di ridurre il *Time-to-Market*, sono spesso rilasciati con test insufficienti.

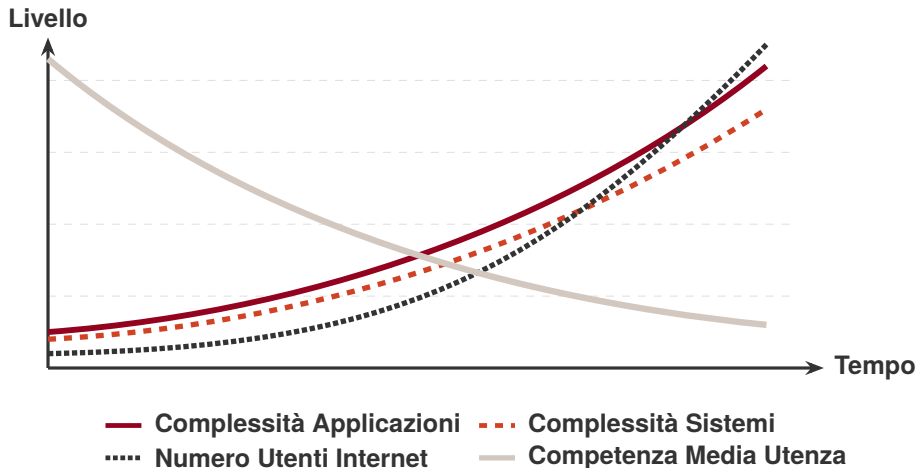
- **Crescita delle Vulnerabilità (CVE)**

Il numero di vulnerabilità note registrate ufficialmente sulla piattaforma CVE mostra un'impennata drammatica, superando le 45.000 segnalazioni nel 2025.



Evoluzione delle Vulnerabilità

Interazione tra Complessità Tecnologica e Competenza dell'Utenza



The background is a solid dark red color. There are two large, thick orange circular arcs. One arc starts from the left edge and curves upwards and to the right, ending near the top center. The other arc starts from the bottom right and curves upwards and to the left, ending near the bottom center. These arcs frame the central text.

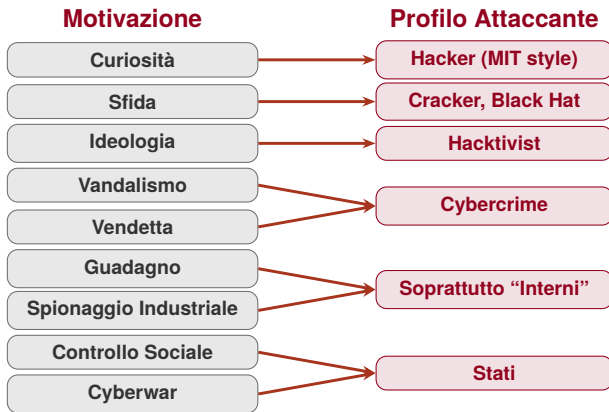
Attaccanti

Condividere il significato dei termini

- HACKER (?)
- CRACKER
- LAMER
- BLACK HAT
- WHITE HAT
- Nell'ambito del corso si userà il termine ATTACKER o AVVERSARI. HACKER è un complimento da meritare!

Il Mondo degli Attacchi

Mappatura tra Motivazioni e Profili degli Attaccanti



Evoluzione degli “attacker”

- **Anni '70: *nasce la cultura hacker***
 - Inoffensiva nella maggior parte dei casi
 - Raramente malintenzionata
- **Anni '80: *si diffonde la cultura hacker***
- **Anni '90: *Internet vandals***
 - Prevalentemente giovanile
 - Spesso malintenzionata, ma non per denaro
 - Intrusioni nei sistemi, Diffusione virus, Denial-of-Service
- **Anni 2000: *nascono i professionisti del cybercrime***
 - “I giovani sono cresciuti: questo è il loro lavoro”
 - La motivazione è essenzialmente economica
 - **SPAM**, nato come strategia di Web marketing, oggi nasconde: frodi (es., 419 advance fee fraud), phishing, diffusione di malware, ecc.
 - **Brand impersonification**: la tattica più comune per acquisire informazioni personali (credenziali di accesso, identità, altri dati)
- **Presente/futuro: *cyberwar, cyberterrorism***

Motivazioni degli attacker “old style”

- Principi hacker
- Sfida, anche se..
 - Pochi attacker individuano e sfruttano vulnerabilità precedentemente sconosciute
 - La stragrande maggioranza degli attacker ripete attacchi noti e documentati
- **Fama** all'interno dei “circoli”
- Soggetti dediti ad ideare codici in grado di infettare le risorse nella Rete

Motivazioni degli attacker “moderni”

- Guadagno personale
- Assunti dalla criminalità organizzata (*Mafia boys*)
- Spionaggio industriale e/o statale
- Ideologia
 - Hacktivism (Hacking + Activism)
 - Cyberterrorismo
- Squilibrio mentale/Stupidità

E non dimentichiamo: l'attacker interno

- Il pericolosissimo **attacker interno**, con varie possibili motivazioni:
 - Frustrazioni lavorative
 - Licenziamenti ritenuti ingiusti
 - Ambizioni di carriera frustrate
 - Corruzione
 - Ricatto
 - Difficoltà finanziarie
- I dipendenti hanno molte informazioni che un esterno non conosce e spesso trovano le porte (quelle fisiche) aperte!

Tipiche azioni riscontrate in università

- Uso di identità elettronica di altri
- Non rispettare le regole di sicurezza di accesso
- Scaricare e installare software proprietario senza licenza
- Scaricare file (musica, video, libri) protetti da diritto di autore
- Più rare, ma ci sono state anche azioni di:
 - Installazione di spyware e rootkit nei computer delle biblioteche
 - Hosting di archivio di materiale pornografico

Tipiche scuse

- “Non sapevo cosa stavo facendo”
- “Non sapevo che fosse sbagliato/proibito”
- “Non stavo pensando”
- “Avendo potuto farlo, pensavo che fosse lecito”
- “Avendo potuto accedere, l’ho usato”
- “Non ho fatto niente di grave. Perché siete così arrabbiati per questo fatto?”
- **“Ignorantia legis\...”: non conoscere le regole interne e la legge non può essere accettata come difesa**

Motivazione dei professionisti

1 Soldi

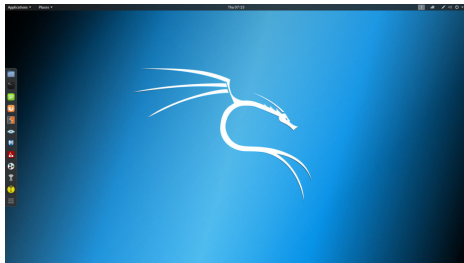
- Negli anni '50 al rapinatore di banche Willie Sutton fu chiesto perché rapinava le banche.
 - Risposta: “That’s where the most money is”
 - **Oggi, molti soldi si trovano in Internet e Web**
 - **Così come quasi tutte le informazioni possono essere trasformate in soldi**
- **Attacchi:** truffe, ricatti, riciclaggio di denaro,
 - furti di denaro e informazioni,...

Notizie

- La **buona notizia**: c'è una piccola minoranza di criminali tra i miliardi di utenti Internet
- La **cattiva notizia**:
 - Un ladro di automobili può rubare solo un'auto alla volta
 - Un singolo criminale da un solo computer può causare danni ad un numero elevatissimo di reti e di computer sfruttando “aiutanti software”

Opportunità per gli attacker

- Per violare una cassaforte, un ladro deve superare molte barriere fisiche, allarmi, e deve sapere come violare una cassaforte
- Per violare un computer (nella maggior parte dei casi) non ci sono barriere fisiche e ci sono poche barriere logiche
- Molti attacker non devono essere “maghi” del computer, ma devono sapere dove scaricare qualche programma scritto da altri che conoscono bene i computer
 - O, al massimo, riuscire ad installare OS particolari...



Tempo di “sopravvivenza”

- Un computer non protetto collegato ad Internet subisce tentativi di attacco mediamente:
 - 2003: entro 55 minuti
 - 2004: entro 20 minuti
 - 2007: entro 4 minuti
 - 2009: entro 1 minuto
 - Oggi: entro pochi secondi

Tempo di “sopravvivenza”

- Nostri studi (datati 2010) hanno rilevato:
 - una media di un attacco al minuto su un PC domestico con sistema operativo Windows collegato a una delle più diffuse linee ADSL
 - in una settimana, sono state raccolte circa 379 tipologie di attacchi diversi (non 379 attacchi, ma 379 tipi di attacchi!)
 - Purtroppo, non esiste un unico strumento che sia in grado di difenderci da tutti e 379 i tipi di attacchi

Gli 8 modi prevalenti per attaccarvi

- 1 **Applicativi non aggiornati**
- 2 **Sistemi operativi obsoleti** (10.9% usa ancora Windows XP, che non è più mantenuto da anni!)
- 3 **Malware** preso tramite allegati di posta e siti Web infetti
- 4 **Password banali**, di default, non aggiornate, usate per servizi diversi e di diversa importanza
- 5 **Phishing** (con agganci tramite email e social network)
- 6 **Man-in-the-browser** (quale conseguenza dei precedenti)
- 7 **Uso di computer condivisi** in hotel, aeroporti, \dots{}
- 8 **Uso di Wi-Fi aperte**

Principi Fondamentali di Cyber Security

Triade CIA

(Una linea guida per la misura della sicurezza informatica)

- Per sopperire al problema di valutazione della sicurezza informatica e codificare meglio il gergo tecnico, si mappano gli obiettivi della sicurezza nella triade CIA:
 - **C**onfidentiality (Riservatezza)
 - **I**ntegrity (Integrità)
 - **A**vailability (Disponibilità)

Triade CIA

(Una linea guida per la misura della sicurezza informatica)

- La Triade CIA serve come strumento per guidare lo sviluppo delle tecnologie informatiche e delle reti in ottica di sicurezza in base ai diversi obiettivi delle strategie attuabili.

Confidentiality

(Confidenzialità o Riservatezza)

- *La **confidenzialità** è l'obiettivo della sicurezza che si occupa di garantire che le informazioni sensibili sono accedute solamente da personale autorizzato a farlo e mantenute inaccessibili a chi non è autorizzato a possederle.*

Confidentiality

(Tecniche e metodologie per l'implementazione)

- Esistono diverse tecniche che permettono di garantire la **confidenzialità** delle informazioni:
 - Cifrando le informazioni
 - Cifratura a chiave simmetrica o privata
 - Cifratura a chiave asimmetrica o pubblica

Confidentiality

(Tecniche e metodologie per l'implementazione)

- Esistono diverse tecniche che permettono di garantire la **confidenzialità** delle informazioni:
 - Cifrando le informazioni
 - Cifratura a chiave simmetrica o privata
 - Cifratura a chiave asimmetrica o pubblica
 - Controllando gli accessi
 - Autenticando gli utenti
 - Fornendo un accesso basato sui ruoli aziendali
 - Verificando l'identità ad ogni accesso

Confidentiality

(Tecniche e metodologie per l'implementazione)

- Esistono diverse tecniche che permettono di garantire la **confidenzialità** delle informazioni:
 - Cifrando le informazioni
 - Cifratura a chiave simmetrica o privata
 - Cifratura a chiave asimmetrica o pubblica
 - Controllando gli accessi
 - Autenticando gli utenti
 - Fornendo un accesso basato sui ruoli aziendali
 - Verificando l'identità ad ogni accesso
 - Implementando specifiche policy di sicurezza
 - Legate alla password o ai meccanismi di autenticazione degli utenti
 - Impostando meccanismi di gestione dei dati aziendali

Integrity

(Integrità)

- *L'**integrità** delle informazioni è l'obiettivo della sicurezza che si occupa di garantire che le informazioni siano mantenute in un formato coerente con la loro rappresentazione originale, evitando modifiche o cancellazioni non autorizzate*

Integrity

(Tecniche e metodologie per l'implementazione)

- Esistono diverse tecniche che permettono di garantire l'**integrità** delle informazioni:
 - Funzioni di Hash

Integrity

(Tecniche e metodologie per l'implementazione)

- Esistono diverse tecniche che permettono di garantire l'**integrità** delle informazioni:
 - Funzioni di Hash
 - Firme digitali

Integrity

(Tecniche e metodologie per l'implementazione)

- Esistono diverse tecniche che permettono di garantire l'**integrità** delle informazioni:
 - Funzioni di Hash
 - Firme digitali
 - Codici a rilevazione d'errore

Availability

(Disponibilità)

- *La **disponibilità** delle informazioni è l'obiettivo della sicurezza che si occupa di garantire che le informazioni siano disponibili per coloro che devono utilizzarle.*

Availability

(Tecniche e metodologie per l'implementazione)

- Esistono diverse tecniche che permettono di garantire la **disponibilità** delle informazioni:
 - Strategie di backup
 - Completo
 - Incrementale
 - Differenziale

Availability

(Tecniche e metodologie per l'implementazione)

- Esistono diverse tecniche che permettono di garantire la **disponibilità** delle informazioni:
 - Strategie di backup
 - Completo
 - Incrementale
 - Differenziale
 - Ridondanza
 - Hardware
 - Software
 - Dei Dati

Availability

(Tecniche e metodologie per l'implementazione)

- Esistono diverse tecniche che permettono di garantire la **disponibilità** delle informazioni:
 - Strategie di backup
 - Completo
 - Incrementale
 - Differenziale
 - Ridondanza
 - Hardware
 - Software
 - Dei Dati
 - Failover
 - Attivo
 - Passivo

Availability

(Tecniche e metodologie per l'implementazione)

- Esistono diverse tecniche che permettono di garantire la **disponibilità** delle informazioni:
 - Strategie di backup
 - Completo
 - Incrementale
 - Differenziale
 - Ridondanza
 - Hardware
 - Software
 - Dei Dati
 - Failover
 - Attivo
 - Passivo
 - Bilanciamento del carico (load balancing)

Limiti della Triade CIA

(Che esistono quando è già implementata correttamente)

- Che garanzie di sicurezza ci fornisce la triade CIA contro:
 - Identità falsificate
 - Dati creati in maniera fraudolenta
 - Mancanza di fiducia nella comunicazione

Go Beyond CIA

(Questa è una JoJo Reference btw)

- Esistono diverse tecniche e metodologie che aumentano l'efficacia della triade CIA per la gestione della sicurezza delle reti e delle comunicazioni, come:
 - Il modello AAA
 - Garanzia del Non Ripudio
 - Paradigma del Defence In Depth
 - Principio del Minimo Privilegio

Il Modello AAA

(Autenticazione, Autorizzazione, Accounting)

- Il modello AAA è un framework di sicurezza che **controlla l'accesso** alle risorse informatiche, **applica policy** e ne **verifica l'utilizzo**.
- AAA e i suoi processi svolgono un ruolo essenziale nella gestione della sicurezza monitorando gli utenti e le loro attività mentre sono connessi.

Autenticazione

(Il modello AAA - AuthN)

- **L'autenticazione** è la pratica che prevede l'identificazione degli utenti mediante la fornitura di **credenziali di accesso univoche**.
- I tipi di autenticazione possono essere basati su
 - Informazioni che conosci
 - Dispositivi che possiedi
 - Caratteristiche fisiche personali

Autenticazione

(Il modello AAA - AuthN)

- **L'autenticazione** è la pratica che prevede l'identificazione degli utenti mediante la fornitura di **credenziali di accesso univoche**.
- I tipi di autenticazione possono essere basati su
 - Informazioni che conosci
 - Dispositivi che possiedi
 - Caratteristiche fisiche personali
- **Un buon sistema di Autenticazione prevede l'utilizzo di almeno due di queste tipologie (meglio se di classi diverse)**

Autorizzazione

(Il modello AAA - AuthZ)

- **L'autorizzazione** è la pratica che prevede **la definizione dei permessi di accesso** ad un utente a seguito della sua autenticazione.
- L'autorizzazione permette di specificare, per ogni utente e ogni servizio cui vuole accedere, il perimetro di operatività legittimo entro il quale l'utente può operare.
- Simile alle *capabilities* dei sistemi UNIX.

Accounting

(Il modello AAA)

- **L'accounting** (o accontabilità) è la pratica di tenere traccia delle attività degli utenti mentre accedono ad una rete e/o ad un servizio, monitorando:
 - L'istante dell'access
 - La durata dell'accesso
 - I dati scambiati
 - Indirizzo IP di accesso
 - URI utilizzato
- Per ogni servizio utilizzato

Accounting

(Il modello AAA)

- L'accounting può essere utilizzato per fini di fatturazione (piattaforme Cloud) e per monitorare le attività su un particolare servizio/sistema al fine di **identificare attività anomale**.

Non Ripudio

(Aka, l'impossibilità di negare di aver compiuto un'azione)

- Il **non ripudio** si riferisce alla condizione secondo la quale l'autore di una particolare attività non può negare di averla svolta, mantenendo al tempo stesso garanzie di affidabilità della comunicazione.
- La garanzia del non ripudio fornisce:
 - Proof of Origin
 - Integrity
 - Delivery of data

Non Ripudio

(Aka, l'impossibilità di negare di aver compiuto un'azione)

- Diversamente dall'Integrità della Triade CIA, il **non ripudio** estende il concetto applicandolo non solo ai dati in un loro particolare stato (*at rest, in motion*) ma a tutti gli utenti coinvolti nella trasmissione ad ogni istante della stessa.

Paradigma Defence In Depth

(Perché gli antichi romani hanno fatto storia anche in informatica)

- Il paradigma **Defence In Depth** (o DiD) consiste nella stratificazione delle risorse informatiche di protezione, rallentando la penetrazione di eventuali attacchi per fornire il tempo necessario per una efficace reazione protettiva.

Paradigma Defence In Depth

(Perché gli antichi romani hanno fatto storia anche in informatica)

- Un classico esempio di DiD applicata ad un sistema di riferimento è l'autenticazione multifattore in un sistema di accesso: l'attaccante non dovrà superare solamente l'ostacolo di un singolo meccanismo di autenticazione (*user:pass*) ma di diversi meccanismi, ognuno con le proprie peculiarità

In cosa consiste

(Defence in Depth)

- La **strutturazione in più livelli** è sicuramente l'asso nella manica di questa strategia, nonché la chiave della sua efficacia.
- Basando **più sistemi di sicurezza** su **differenti livelli** si va notevolmente ad **ottimizzare il livello di protezione**.
- **Potrebbe infatti accadere che, durante un attacco, un livello non dovesse funzionare o venisse facilmente bypassato: in questo caso, entrerebbe in funzione il successivo, garantendo l'aumento di tempo utile e necessario per una risposta efficace e complementare.**

Difesa Multilivello

(Defence in Depth)

- Alla base della **Defense in Depth** vi è la **Difesa Multilivello**, che utilizza un insieme di soluzioni per **restringere la superficie di attacco**, in modo tale che il perimetro di rete sia il più possibile **protetto da ogni lato**.
- L'aumento di quantità e complessità delle minacce ha infatti reso necessaria la combinazione delle due tecniche così da
 - ottimizzare la gestione dei sistemi informatici
 - e massimizzarne la protezione

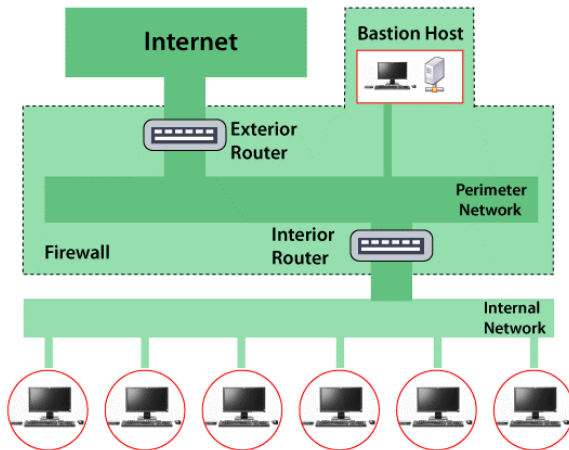
Difesa Multilivello

(Defence in Depth)

- Le due tipologie di difesa (**DiD** e **Multilivello**) possono essere viste come complementari, poiché mentre la **Defense in Depth**, organizzata su più stratificazioni, **rallenta l'ingresso di terzi non autorizzati**, la **Difesa Multilivello** protegge in modo più efficiente le reti e gli endpoint.

Difesa Multilivello in ambito di rete

(Defence in Depth)



Screened subnet

Tre componenti che interagiscono: router esterno, bastion host, router interno

- Evoluzione dell'architettura **two-legged network** e **screened-host gateway**. (solo citate per onor di cronaca, ormai sono obsolete per qualsiasi cosa che non sia una rete casalinga)
- **Router esterno:** filtra il traffico tra Internet e DMZ secondo le politiche definite per l'accesso ai server della DMZ consentendo esclusivamente il transito di pacchetti (selettivo) da e verso il bastion host
- **Router interno:** protegge sia la rete privata da attacchi provenienti da Internet sia i server della DMZ da eventuali attacchi provenienti dall'interno della rete
- È anche possibile configurare i router esterno e interno in modo da non permettere alcun traffico da Internet verso la rete interna o da consentire il transito di traffico **considerato fidato** tra Internet e la rete interna

De-Militarized Zone (DMZ)

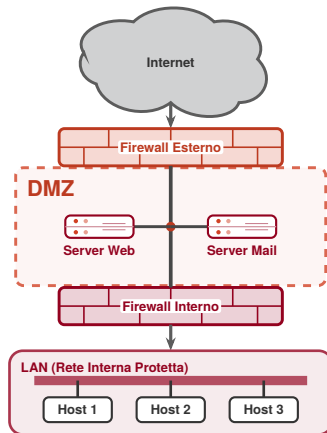
Architettura di rete e posizionamento dei servizi

- **Cos'è la DMZ:**

Una sottorete isolata che non fa parte né della rete interna né della rete esterna (Internet).

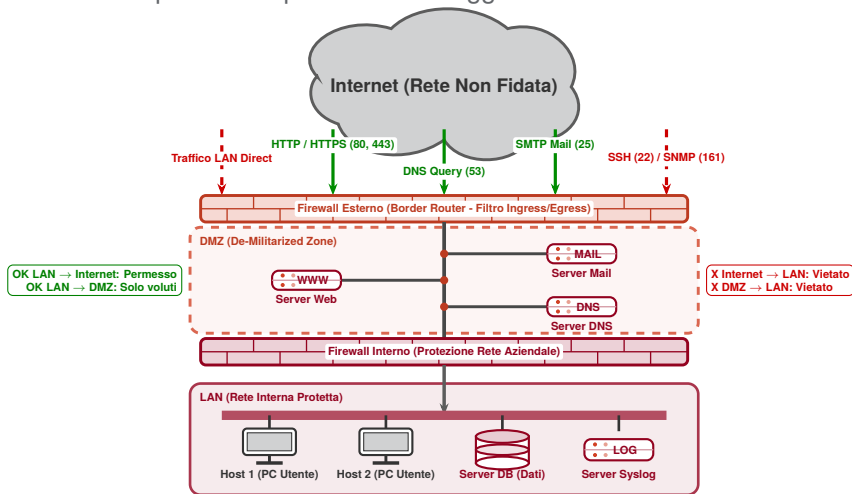
- **Scopo Principale:**

- Minimizza l'esposizione della rete interna ad attacchi esterni.
- Ospita esclusivamente i server che erogano servizi pubblici (Web, Mail, DNS) accessibili da Internet.



Miglior architettura di supporto

Rappresentazione completa delle politiche di filtraggio ed isolamento



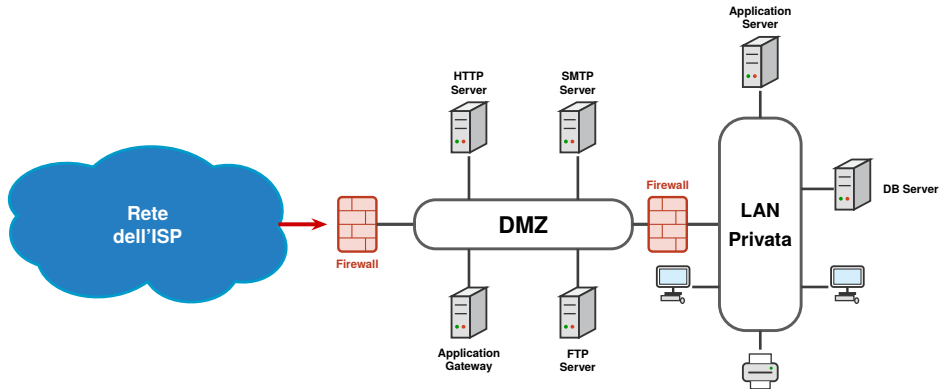
DMZ

(Tipiche politiche adottate)

Rete di partenza	Rete di destinazione	Traffico permesso
LAN	Internet	Tutto (o quasi)
LAN	DMZ	Solo protocolli voluti
Internet	DMZ	Solo protocolli voluti
Internet	LAN	Nessuno (tranne risposte da richieste)
DMZ	Internet	Solo protocolli voluti
DMZ	LAN	Nessuno (tranne risposte da richieste)

Oltre la difesa del perimetro esterno

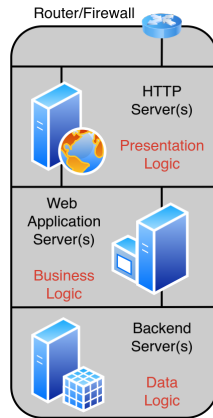
Architettura multi-livello con DMZ e LAN Privata



Architettura Web multi-livello

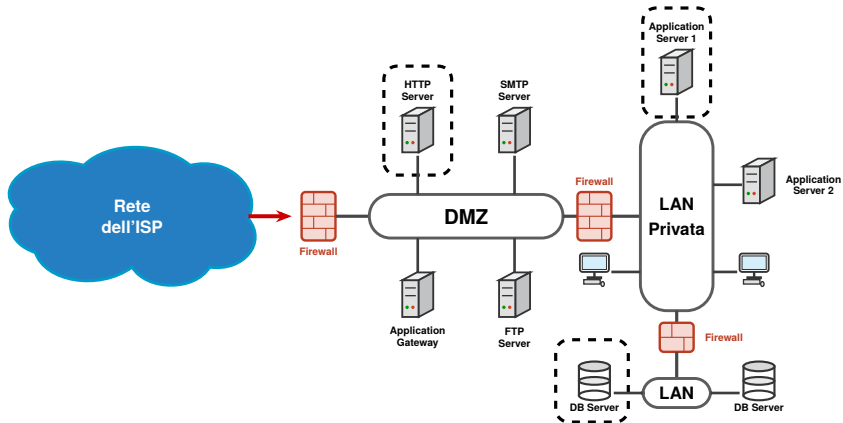
(Scalabilità e sicurezza)

- **Sicurezza nel filtraggio interno** (Concettuale)



Architettura Web multi-livello

(Filtrare e isolare tra i livelli)



Principio del Minimo Privilegio

“Più ti limito e meno danni puoi fare”

- Il principio del **minimo privilegio** è un concetto secondo cui un'utente, un programma, o un'altra entità deve avere accesso alle sole risorse, ai dati e alle funzioni strettamente necessarie per il proprio ruolo lavorativo.
- **Lo scopo è quello di ridurre i danni potenziali derivanti da un account compromesso o da una minaccia interna, limitando la superficie d'attacco.**

Principio del Minimo Privilegio

“Più ti limito e meno danni puoi fare”

- I sistemi che permettono una gestione secondo il principio del minimo privilegio sono fortemente integrati con tecnologie e modelli aziendali (es., RBAC) e prevedono la definizione di policy aziendali specifiche.
- **Come tutti i processi aziendali, queste policy devono essere continuamente soggette a revisioni e aggiornamenti!**

Follow-up-up

E per una carriera nell'ambito che si deve fare?

- **Risposta semplice:** ottenere certificazioni (e i corsi universitari vi forniscono una solida base di partenza)
- **Risposta più corretta:** dipende da che tipo di percorso lavorativo volete perseguire (<https://pauljerimy.com/security-certification-roadmap/>)

Categorie di percorsi lavorativi

<https://pauljerimy.com/security-certification-roadmap/>

- **Communication and Network Security:** The communication and network security domain covers the ability to secure communication channels and networks.
- **IAM:** The Identity and Access Management domain covers the attacks that target the human gateway to gain access to data
- **Security Architecture and Engineering:** The security architecture and engineering domain covers important topics concerning security engineering plans, designs and principles
- **Asset Security:** The asset security domain deals with the issues related to the collection, storage, maintenance, retention and destruction of data
- **Security and Risk Management:** The security and risk management domain covers general on skills related to the implementation of user awareness programs as well as security procedures

Categorie di percorsi lavorativi

<https://pauljerimy.com/security-certification-roadmap/>

- **Security Assessment and Testing:** The security assessment and testing domain deals with all the techniques and tools used to find system vulnerabilities, weaknesses and potential areas of concern not addressed by security procedures and policies
- **Software Security:** The software security domain deals with implementing software-based security protocols with environments for which the IT professional is responsible
- **Security Operations:** The security operations domain covers topics ranging from investigations and digital forensic to detection and intrusion prevention tools, sandboxing and firewalls. It is generally composed of two macro areas:
 - **Blue teaming operations:** Covers different topics related to detecting incidents, analyzing the attacker behavior and improve the system security
 - **Red teaming operations:** Covers different topics related to penetration testing different parts of the system and exploitation to identify unknown vulnerabilities in a target system